

Scanned Code Report

AUDITAGENT

AUDITAGENT

Important Notice

This Report has been generated entirely by AI and has not been manually reviewed by Nethermind's security team. It does not constitute a full security audit. Projects may not represent or imply otherwise in any public communication. All findings, observations, and recommendations may contain errors or omissions and must be independently verified by a qualified human reviewer before being acted upon. This Report should be used as a supplementary tool only, alongside professional security practices.

Code Info

[Auditor Scan](#)

#	Scan ID 1	✦	Date September 17, 2026
📦	Organization ensuro	📦	Repository enzyme-onyx-rebalancer
📁	Branch main	📄	Commit Hash 875def37...9cc62321

Contracts in scope

contracts/OnyxRebalancer.sol contracts/OnyxRedeemer.sol contracts/interfaces/IOnyxVault.sol
contracts/interfaces/IRedemptionHandler.sol contracts/interfaces/IValuationHandler.sol

Code Statistics

🐛	Findings 3	📄	Contracts Scanned 5	☰	Lines of Code 208
---	---------------	---	------------------------	---	----------------------

Findings Summary



Total Findings

■ High Risk (0)
■ Medium Risk (1)
■ Low Risk (1)

■ Info (0)
■ Best Practices (1)

Code Summary

The protocol provides automation and operational tooling for the Onyx Vault ecosystem, facilitating asset composition management, share valuation updates, and the execution of queued redemptions. Onyx Vaults hold a combination of USDC and eTokens (rebasing tokens pegged 1:1 to USDC) and support asynchronous redemption flows (ERC-7540-like). The protocol comprises two core contracts:

- **OnyxRebalancer**: Manages the internal liquidity ratio of the Onyx Vault between USDC and eTokens. Authorized callers can supply eTokens to receive equivalent USDC or supply USDC to receive equivalent eTokens, allowing automated or manual rebalancing of the vault's asset pool.
- **OnyxRedeemer**: Manages share valuation synchronization and redemption fulfillment. It triggers net share value calculations via the vault's valuation handler and processes batches of pending redemption requests through the redemption handler.

Both contracts incorporate role-based access control leveraging OpenZeppelin's AccessControl pattern with an extended open-role mechanism. If a role is granted to the zero address (`address(0)`), the restricted function becomes permissionless and callable by any user.

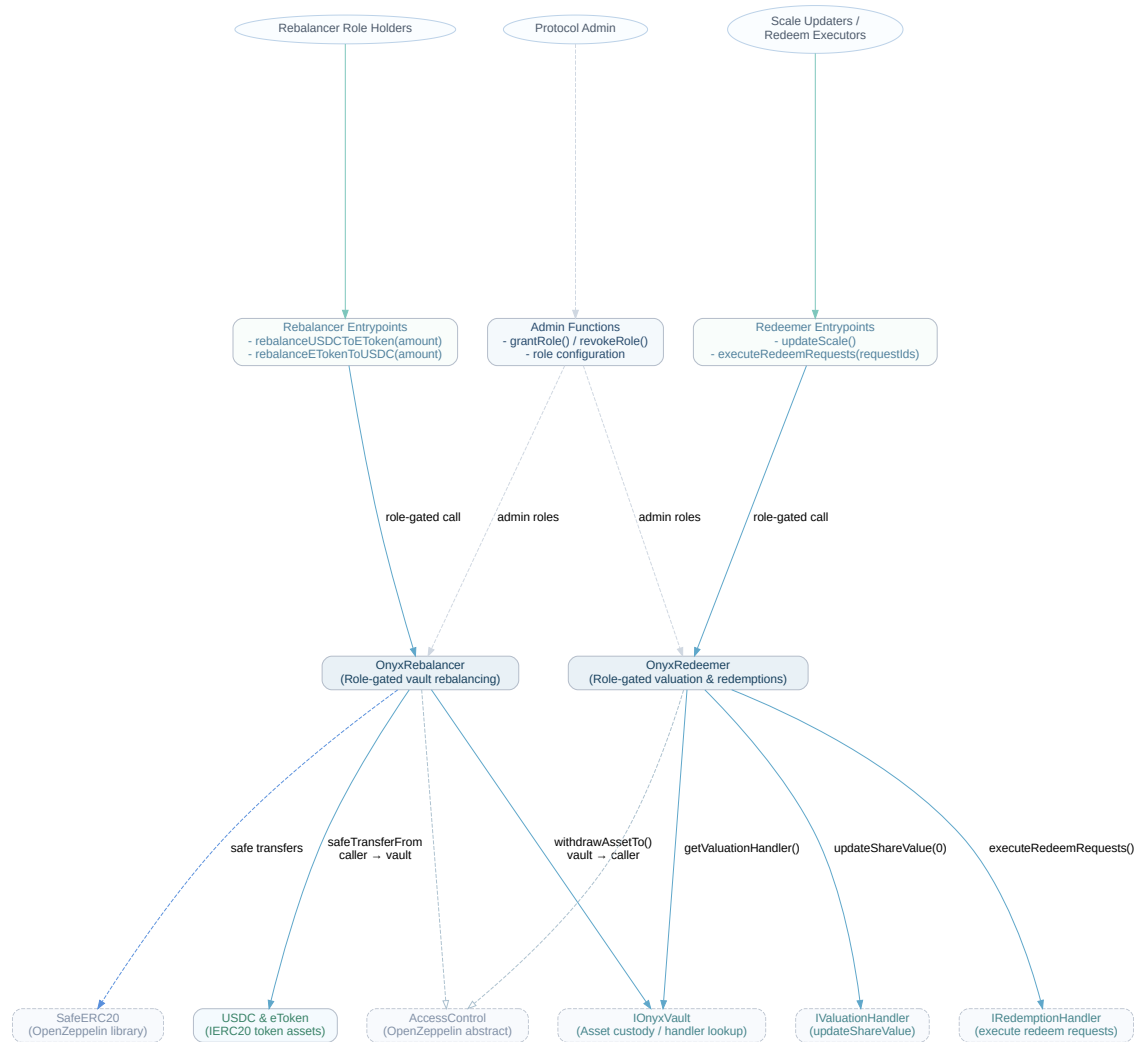
Main Actors

- **Rebalancers**: Entities holding `USDC_TO_ETOKEN_ROLE` or `ETOKEN_TO_USDC_ROLE` (or any caller if assigned to `address(0)`) who deposit one asset type into the vault to receive the equivalent counter-asset.
- **Scale Updaters**: Entities with `SCALE_UPDATER_ROLE` (or any caller if assigned to `address(0)`) who trigger on-chain valuation updates for the vault's shares.
- **Redeem Executors**: Entities with `REDEEM_EXECUTOR_ROLE` (or any caller if assigned to `address(0)`) who trigger share valuation updates and execute batches of user redemption requests.
- **Admin**: The account holding `DEFAULT_ADMIN_ROLE` responsible for managing role assignments.

Main Entry Points

- `OnyxRebalancer.rebalanceUSDCtoEToken(uint256 amount)`: Transfers eToken from the caller to the vault and withdraws an equivalent amount of USDC to the caller. Callable by Rebalancers.
- `OnyxRebalancer.rebalanceETokenToUSDC(uint256 amount)`: Transfers USDC from the caller to the vault and withdraws an equivalent amount of eToken to the caller. Callable by Rebalancers.
- `OnyxRedeemer.updateScale()`: Updates the vault's net share value via the valuation handler. Callable by Scale Updaters.
- `OnyxRedeemer.executeRedeemRequests(uint256[] calldata requestIds)`: Updates the vault's net share value and executes the specified redemption requests via the redemption handler. Callable by Redeem Executors.
- `AccessControl.grantRole(bytes32 role, address account)`: Grants a specified role to an account. Callable by the Admin.
- `AccessControl.revokeRole(bytes32 role, address account)`: Revokes a specified role from an account. Callable by the Admin.
- `AccessControl.renounceRole(bytes32 role, address callerConfirmation)`: Renounces a role currently held by the caller. Callable by any role holder.

Code Diagram



✦ 1 of 3 Findings

contracts/OnyxRebalancer.sol

Unchecked eToken parity allows impaired eToken to be exchanged for vault USDC at a fixed 1:1 rate

• Medium Risk

rebalanceUSDCToEToken and rebalanceETokenToUSDC always exchange identical nominal amounts and perform no check that the incoming eToken and outgoing USDC have equivalent economic and liquidity value. If eToken materially depegs or cannot provide equivalent redemption liquidity, an authorized caller—or any caller when USDC_TO_ETOKEN_ROLE is open—can transfer impaired eToken into the vault and withdraw the same nominal amount of liquid USDC. Repeated calls can shift the impairment to vault shareholders and exhaust the vault's available USDC. The rebalance path should enforce an acceptable parity/liquidity condition or otherwise bound and control exposure during impairment.

Severity Note:

- Severe loss is assumed only if eToken materially depegs or cannot redeem at par; this file hard-codes a 1:1 peg and does not itself prove a decimal or pricing mismatch.
- Permissionless exploitation additionally assumes an admin grants the direction role to address(0), which is optional and not the constructor default.

✦ 2 of 3 Findings

contracts/OnyxRedeemer.sol

Hardcoded zero prevents accounting for nonzero untracked positions in share-value updates

• Low Risk

OnyxRedeemer._updateScale() always calls the active valuation handler as updateShareValue(0), even though IValuationHandler defines the argument as the value of positions not tracked on-chain. Consequently, neither updateScale() nor executeRedeemRequests() can submit the correct valuation input when that adjustment is nonzero. In the redemption path, any resulting valuation update is immediately followed by execution of the supplied requests. The redeemer should accept or securely obtain the required adjustment, or enforce that this integration is only used with vault configurations for which the correct untrackedPositionsValue is always zero.

Severity Note:

- Material harm assumes the vault's correct untrackedPositionsValue is nonzero; that is not demonstrated in OnyxRedeemer and may be intentionally out of scope for this integration.
- No path is shown for an unprivileged party to set or fake the untracked adjustment; the defect is inability to pass a nonzero value, not attacker-controlled NAV.

✦ 3 of 3 Findings

📁 contracts/OnyxRedeemer.sol

Redemption execution does not reject a zero refreshed net share value

• Best Practices

OnyxRedeemer.executeRedeemRequests() invokes *updateScale()*, discards the returned *netShareValue*, and then unconditionally calls *redemptionHandler.executeRedeemRequests(requestIds)* if the valuation call did not revert. Because zero is a valid *uint256* return value, the redeemer does not fail closed when the refresh successfully reports zero, even if zero represents an invalid or uninitialized valuation for the configured valuation and redemption handlers. The settlement path should validate the refreshed value—at minimum according to the configured handler's valid-value semantics—before executing queued requests.

Disclaimer

No Guarantee of Accuracy or Completeness. Kindly note, no guarantee is being given as to the accuracy and/or completeness of any of the outputs the AuditAgent may generate, including without limitation this Report. The results set out in this Report may not be complete nor inclusive of all vulnerabilities. The AuditAgent is provided on an 'as is' basis, without warranties or conditions of any kind, either express or implied, including without limitation as to the outputs of the code scan and the security of any smart contract verified using the AuditAgent.

This Report is not a security audit. This Report has been generated automatically by AuditAgent, an AI-powered automated code scanning tool. It does not constitute, and must not be represented or relied upon as constituting, a full or comprehensive security audit conducted by Nethermind or any of its personnel. A formal security audit involves manual review by experienced human auditors and is a materially different service. If you require a full security audit, please contact Nethermind's security audit team at auditagent@nethermind.io

Use of Nethermind's name. "Nethermind" is a trade mark of Demerzel Solutions Limited. Use of this Report does not authorise you to represent that your code or smart contract has been "audited by Nethermind" or to use any similar phrase. Any such representation would be false, misleading, and an infringement of Nethermind's intellectual property rights.] No Endorsement or Security Guarantee. Blockchain technology remains under development and is subject to unknown risks and flaws. This Report does not indicate the endorsement of any particular project or team, nor guarantee its security. Neither you nor any third party should rely on this Report in any way, including for the purpose of making any decisions to buy or sell a product, service or any other asset.

Disclaimer. To the fullest extent permitted by law, Nethermind disclaims any liability in connection with this Report, its content, and any related services and products and your use thereof, including, without limitation, the implied warranties of merchantability, fitness for a particular purpose, and non-infringement. Nethermind does not warrant, endorse, guarantee, or assume responsibility for any product or service advertised or offered by a third party through the product, any open source or third-party software, code, libraries, materials, or information linked to, called by, referenced by or accessible through the report, its content, and the related services and products, any hyperlinked websites, any websites or mobile applications appearing on any advertising, and Nethermind will not be a party to or in any way be responsible for monitoring any transaction between you and any third-party providers of products or services. As with the purchase or use of a product or service through any medium or in any environment, you should use your best judgment and exercise caution where appropriate.

FOR AVOIDANCE OF DOUBT, THE REPORT, ITS CONTENT, ACCESS, AND/OR USAGE THEREOF, INCLUDING ANY ASSOCIATED SERVICES OR MATERIALS, SHALL NOT BE CONSIDERED OR RELIED UPON AS ANY FORM OF FINANCIAL, INVESTMENT, TAX, LEGAL, REGULATORY, OR OTHER ADVICE.